

- **Expediente N.º: EXP202312988**

RESOLUCIÓN DE PROCEDIMIENTO SANCIONADOR

Del procedimiento instruido por la Agencia Española de Protección de Datos y en base a los siguientes

ANTECEDENTES

PRIMERO: Don **A.A.A.** (en adelante, la parte reclamante) con fecha 25 de julio de 2023 interpuso reclamación ante la Agencia Española de Protección de Datos. La reclamación se dirige contra el COLEGIO VIRGEN DE EUROPA, S.L. con NIF B28773794 (en adelante, el COLEGIO). Los motivos en que basa la reclamación son los siguientes:

La parte reclamante declara que el COLEGIO creó a su hija menor de 14 años un correo electrónico *****EMAIL.1**, sin haberse recabado el consentimiento de los tutores en la creación de dicho correo electrónico ni para trabajar con un perfil de Classroom.

El 20 de noviembre de 2022 tuvo conocimiento de que alguien había suplantado la identidad de su hija y se hizo pasar por ella escribiendo correos desde la cuenta *****EMAIL.1** a diferentes personas, así como accediendo al contenido de su perfil en Classroom y escribiendo en su nombre.

Dichos hechos fueron comunicados al COLEGIO.

La parte reclamante afirma que el COLEGIO no ha notificado la brecha de seguridad ni le ha dado ninguna importancia al hecho.

A su vez, destaca que solicitaron los registros de eventos de Classroom con la IP y no se los han facilitado. Asimismo, declara que las medidas de seguridad no eran las óptimas; ya que la contraseña del correo electrónico para todos los niños y niñas eran las iniciales de la menor más la fecha de nacimiento de la madre, sin forzar el cambio de la misma, dando la posibilidad a una suplantación de identidad sin mucho esfuerzo.

La parte reclamante señala que en la política de privacidad de la parte reclamada no constan los datos de contacto del DPD. No obstante, si se busca el DPD en la página www.aepd.es el contacto del DPD es *****EMAIL.2** pero este correo no existe.

Junto a la reclamación se aporta el correo remitido en fecha 20 de noviembre de 2022 para comunicar la incidencia en Classroom y una impresión del email remitido a la dirección de correo electrónico del DPD, que no ha podido ser entregado.

SEGUNDO: De conformidad con el artículo 65.4 de la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales (en adelante LOPDGDD), se dio traslado de dicha reclamación al COLEGIO, para que procediese a su análisis e informase a esta Agencia en el plazo de un mes, de las

acciones llevadas a cabo para adecuarse a los requisitos previstos en la normativa de protección de datos.

El traslado, que se practicó conforme a las normas establecidas en la Ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas (en adelante, LPACAP), fue recogido en fecha 29 de septiembre de 2023 como consta en el certificado que obra en el expediente.

Con fecha de registro 30 de octubre de 2023 se recibe en esta Agencia escrito presentado el 27 de octubre de respuesta indicando, textualmente, que:

“3. Informe sobre las causas que han motivado la incidencia que ha originado la reclamación.

Respecto a las causas que han motivado la incidencia, el origen es con motivo del traslado de un posible incidente, por parte del tutor de las menores, ante un posible acceso a la plataforma habilitada para a gestión de la docencia.

4. Informe sobre las medidas adoptadas para evitar que se produzcan incidencias similares, fecha de implantación y controles efectuados para comprobar su eficacia.

En relación al informe relativo a las medidas adoptadas para evitar que se produzcan incidencias similares, fechas de implantación y controles efectuados, se encuentra integrado por las siguientes medidas:

Desde la dirección, somos conscientes de que, en los procesos de gestión de datos, en los que se encuentra involucrado el personal del Colegio, resulta fundamental la formación y concienciación de los mismos, para un adecuado trámite de peticiones, consultas o incidentes que puedan surgir.

Asimismo, en cumplimiento del principio de transparencia, el Colegio revisa periódicamente cualquier tipo de clausulado, formulario o comunicación efectuada, tal y como establece el art. 13 y 14 del Reglamento Europeo de Protección de Datos.

En base a lo anterior, el Responsable del tratamiento, ha definido las siguientes verificaciones, como parte integrante de los procesos existentes:

- Revisión del clausulado en cumplimiento del deber de información, así como, el consentimiento del titular de los mismos o representante, para cada una de las finalidades del tratamiento de datos.*
- De igual modo, se procederá a reforzar el procedimiento de consulta de la política de privacidad.*
- Además, como hemos señalado con anterioridad, al ser conscientes de que la gestión de estos procesos depende de la consciencia y conocimiento por parte del usuario encargado en la entidad, se procedió durante el ejercicio*

de 2022, a la elaboración de un programa formativo, para lograr alcanzar esta cultura de protección de datos.

En este sentido, en esta primera organización, la formación se destinó a los trabajadores/as encargados de la gestión de comunicaciones, bajo el objetivo de formación y concienciación de la totalidad, siendo el contenido del programa formativo:

UNIDAD 1. EL REGLAMENTO EUROPEO DE PROTECCIÓN DE DATOS (UE) 2016/679

UNIDAD 2. FUNDAMENTOS PARA EL TRATAMIENTO DE DATOS.

UNIDAD 3. RESPONSABLE Y ENCARGADO DEL TRATAMIENTO.

UNIDAD 4. DERECHOS DE LOS INTERESADOS.

UNIDAD 5. MEDIDAS DE RESPONSABILIDAD ACTIVA I

UNIDAD 6. MEDIDAS DE RESPONSABILIDAD ACTIVA II

Tal y como anticipamos con anterioridad, los procesos de gestión en materia de protección de datos, se encuentran en constante revisión y valoración, debido a que, desde la entidad, somos conscientes de la exposición constante y necesidad de cumplimiento de las garantías que establece la normativa vigente.”

TERCERO: Con fecha 25 de octubre de 2023, de conformidad con el artículo 65 de la LOPDGDD, se admitió a trámite la reclamación presentada por la parte reclamante.

CUARTO: De acuerdo con el informe recogido de la herramienta AXESOR, la entidad COLEGIO VIRGEN DE EUROPA, S.L. es una mediana empresa constituida en el año 1982, y con un volumen de negocios de 11.181.007 euros en el año 2023.

QUINTO: Con fecha 23 de abril de 2024, la Directora de la Agencia Española de Protección de Datos acordó iniciar procedimiento sancionador a la parte reclamada, con arreglo a lo dispuesto en los artículos 63 y 64 de la LPACAP, por la presunta infracción de los artículos 6.1, 13 y 32 del RGPD, tipificadas las dos primeras en el artículo 83.5 del RGPD y la última en el artículo 83.4 del RGPD.

SEXTO: Notificado el citado acuerdo de inicio conforme a las normas establecidas en la LPACAP, la parte reclamada presentó el 9 de mayo de 2024 escrito de alegaciones en el que, en síntesis, manifestaba que:

1. En relación al primer hecho mencionado en el presente procedimiento sancionador, la creación de la dirección de correo electrónico, mencionan entre otras las siguientes cuestiones:

La situación de creación de la dirección de correo electrónico respondió a una necesidad educativa, y que se llevó a cabo durante la época excepcional del COVID19, ante la necesidad de adaptación rápida de los sistemas educativos existentes hasta el momento.

Por ello, la comunicación de creación de la dirección de correo electrónico se llevó a cabo mediante correos electrónicos con los tutores de los menores, y ante los cuales,

no existió impedimento o negativa por parte del tutor de la menor referida en la reclamación.

Si bien, tras este momento de adaptación excepcional, adaptaron sistemas a la hora de recabar el consentimiento, con los requisitos establecidos por el legislador.

2. Mencionan las medidas de seguridad e instrucciones trasladadas en la gestión de este sistema y que han sido implementadas, en cumplimiento de lo establecido por los artículos 24 y 32 del citado Reglamento Europeo de Protección de Datos

3. En relación a la información otorgada en cumplimiento del deber de información, consagrado en el artículo 13 del Reglamento Europeo de Protección de Datos, debemos señalar las siguientes cuestiones:

Señala que la entidad ha adaptado sus sistemas de tratamiento de la información de datos de carácter personal a lo dispuesto en el Reglamento General de Protección de Datos (UE) 2016/679 y a la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y Garantía de los Derechos Digitales.

El Colegio no permite la recogida de datos, así como el tratamiento, de aquellos datos que no resulten estrictamente necesarios para la finalidad perseguida en cada caso, aportándose los procedimientos implementados por el centro.

4. Nos trasladan las medidas adoptadas, con motivo del incidente surgido en su momento.

SÉPTIMO: Con fecha 18 de octubre de 2024 se dictó propuesta de resolución proponiendo se sancionara a COLEGIO VIRGEN DE EUROPA, S.L., con NIF B28773794, por una infracción del artículo 6.1 del RGPD y de artículo 13 del RGPD tipificadas en el artículo 83.5 del RGPD, y por una infracción del artículo 32 del RGPD tipificada en el artículo 83.4 del RGPD, con las siguientes multas:

- Por la infracción del artículo 6.1 del RGPD, tipificada en el artículo 83.5 de dicha norma, multa administrativa de cuantía 4.500,00 euros.
- Por la infracción del artículo 13 del RGPD, tipificada en el artículo 83.5 de dicha norma, multa administrativa de cuantía 1.000,00 euros.
- Por la infracción del artículo 32 del RGPD, tipificada en el artículo 83.4 de dicha norma, multa administrativa de cuantía 4.500,00 euros.

OCTAVO: Notificada la propuesta de resolución conforme a las normas establecidas en la LPACAP, la parte reclamada presentó el 4 de noviembre de 2024 escrito de alegaciones en el que reitera las manifestaciones ya hechas al acuerdo de inicio.

Lo único nuevo que se ha manifestado por la parte reclamada es que se ha expuesto por parte de la autoridad de control la falta de información sobre el contacto relativo a la figura del Delegado de Protección de Datos, estando en desacuerdo con ello, dado que se encuentra identificada en los diferentes procedimientos, formularios de recogida de datos, clausulados y en la política de privacidad de su página web.

De las actuaciones practicadas en el presente procedimiento y de la documentación obrante en el expediente, han quedado acreditados los siguientes:

HECHOS PROBADOS

PRIMERO: Consta probado en el expediente que el COLEGIO creó un correo electrónico *****EMAIL.1** a una alumna del centro educativo menor de 14 años.

SEGUNDO: Consta acreditado en el expediente mediante declaración de la propia entidad que, en el proceso de creación de dicho correo electrónico, el COLEGIO se limitó a comunicar la creación de las direcciones de correo electrónico mediante el envío de correos electrónicos a los tutores de los menores.

TERCERO: Consta probado en el expediente que, el correo enviado al DPD a la siguiente dirección de correo electrónico *****EMAIL.2** fue devuelto por error en el envío.

CUARTO: Consta probado en el expediente, mediante diligencia de fecha 1 de julio de 2024, que en el registro de la Agencia Española de Protección de Datos consta como dato del DPD la siguiente dirección de correo electrónico *****EMAIL.2**

QUINTO: Consta probado en el expediente, mediante diligencia de fecha 1 de julio de 2024 que, consultada la página web de la entidad reclamada <https://cve.edu.es/politica-de-privacidad/>, en el apartado correspondiente a la política de privacidad no constan los datos de contacto del DPD.

SEXTO: Consta acreditado en el expediente, mediante afirmación de la parte reclamante y aportación de fotografías, que la contraseña del correo electrónico creado por el COLEGIO para todos los niños y niñas eran las iniciales de la menor más la fecha de nacimiento de la madre, sin forzar el cambio de la misma; lo que, facilitó la suplantación de la identidad de la menor.

FUNDAMENTOS DE DERECHO

I

Competencia

De acuerdo con los poderes que el artículo 58.2 del Reglamento (UE) 2016/679 (Reglamento General de Protección de Datos, en adelante RGPD), otorga a cada autoridad de control y según lo establecido en los artículos 47, 48.1, 64.2 y 68.1 de la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales (en adelante, LOPDGDD), es competente resolver este procedimiento la Presidencia de la Agencia Española de Protección de Datos.

Asimismo, el artículo 63.2 de la LOPDGDD determina que: *"Los procedimientos tramitados por la Agencia Española de Protección de Datos se regirán por lo dispuesto en el Reglamento (UE) 2016/679, en la presente ley orgánica, por las disposiciones reglamentarias dictadas en su desarrollo y, en cuanto no las contradigan, con carácter subsidiario, por las normas generales sobre los procedimientos administrativos."*

II

Cuestiones Previas

El artículo 4 del RGPD, bajo la rúbrica “Definiciones”, dispone lo siguiente:

“1) «datos personales»: toda información sobre una persona física identificada o identificable («el interesado»); se considerará persona física identificable toda persona cuya identidad pueda determinarse, directa o indirectamente, en particular mediante un identificador, como por ejemplo un nombre, un número de identificación, datos de localización, un identificador en línea o uno o varios elementos propios de la identidad física, fisiológica, genética, psíquica, económica, cultural o social de dicha persona;

En consecuencia, es evidente que el correo electrónico de una persona, a tenor del artículo 4.1 del RGPD, es un dato personal y su protección, por tanto, es objeto de dicho Reglamento.

En el artículo 4.2 del RGPD se define el concepto de “tratamiento” de datos personales.

2) «tratamiento»: cualquier operación o conjunto de operaciones realizadas sobre datos personales o conjuntos de datos personales, ya sea por procedimientos automatizados o no, como la recogida, registro, organización, estructuración, conservación, adaptación o modificación, extracción, consulta, utilización, comunicación por transmisión, difusión o cualquier otra forma de habilitación de acceso, cotejo o interconexión, limitación, supresión o destrucción”.

En el apartado siete del mismo artículo del RGPD se dispone lo siguiente

7) «responsable del tratamiento» o «responsable»: la persona física o jurídica, autoridad pública, servicio u otro organismo que, solo o junto con otros, determine los fines y medios del tratamiento; si el Derecho de la Unión o de los Estados miembros determina los fines y medios del tratamiento, el responsable del tratamiento o los criterios específicos para su nombramiento podrá establecerlos el Derecho de la Unión o de los Estados miembros”.

En este sentido, debe recordarse que el COLEGIO, es responsable del tratamiento de los datos personales, en el caso concreto que nos ocupa, el correo electrónico de la hija del reclamante, dado que es quien determina los fines y medios del tratamiento de los datos personales.

III

Alegaciones al acuerdo de inicio y a la propuesta de resolución

En respuesta a las alegaciones presentadas por la entidad reclamada se debe señalar lo siguiente:

La entidad expone que.

1. En relación al primer hecho probado del presente

procedimiento sancionador, relativo a la creación de la dirección de correo electrónico, debemos mencionar las siguientes cuestiones:

En primer lugar, el artículo 6.1 del Reglamento General de Protección de Datos (UE) 2016/679, en relación a las bases de legitimación para el tratamiento de datos de carácter personal, contempla entre las mismas, en su apartado b), el necesario tratamiento de los datos para la ejecución de la prestación de servicios (el tratamiento es necesario para la ejecución de un contrato en el que el interesado es parte o para la aplicación a petición de este de medidas precontractuales), y en su apartado a), el consentimiento del titular de los datos o, en el supuesto de menores de 14 años, el consentimiento otorgado por el tutor del mismo.

En este sentido, debemos mencionar que la situación de creación de la dirección de correo electrónico responde a una necesidad educativa, y que, en el caso expuesto, se llevó a cabo durante la época excepcional del COVID19, ante la necesidad de adaptación rápida de los sistemas educativos existentes hasta el momento. La finalidad de creación de esta cuenta responde a la propia ejecución y desarrollo de la formación, no siendo posible, debido a la falta de presencialidad, la ejecución y asistencia de los alumnos/as a través de otras vías que no fuesen las habilitadas en ese momento excepcional.

Con motivo de lo anterior, la comunicación de creación de la dirección de correo electrónico se llevó a cabo mediante correos electrónicos con los tutores de los menores, y ante los cuales, no existió impedimento o negativa por parte del tutor de la menor referida en la reclamación. En prueba de lo anterior, aportamos correos electrónicos (ANEXO I).

Asimismo, tras este momento de adaptación excepcional, adaptamos nuestros sistemas a la hora de recabar la autorización, con los requisitos establecidos por el legislador. En prueba de lo anterior, aportamos documento actual, que se facilita a los tutores para la gestión del classroom (ANEXO II).

En contestación a lo alegado, este Organismo debe reiterar y resaltar que, en ningún caso y a efectos del artículo 6.1 del RGPD, una situación de emergencia como ha sido la pandemia mundial del Covid -19 legitima, por sí misma, el tratamiento de los datos personales sin el consentimiento de sus titulares o de los tutores, en su caso.

Sorprende mucho a este organismo que la falta del consentimiento del titular de los datos o, en el supuesto de menores de 14 años, del consentimiento otorgado por el tutor de los mismos, se haya suplido con una simple posterior comunicación por correo electrónico a los tutores de los menores y, sorprende, aún más, que se le dé todo el valor del propio consentimiento por no constar impedimento o negativa por parte de dichos tutores.

En este sentido, debemos recordar lo preceptuado en el artículo 7 del RGPD “Condiciones para el consentimiento”, que establece que:

“1. Cuando el tratamiento se base en el consentimiento del interesado, el responsable deberá ser capaz de demostrar que aquel consintió el tratamiento de sus datos personales.

El RGPD no establece un mecanismo en concreto sobre cómo el responsable debe ser capaz de probar que ha obtenido un consentimiento válido, teniendo libertad para implementar la forma de obtención y registro que más se adapte a los procesos de la organización, pero, al menos, debe poder acreditar quién otorgó el consentimiento, cuándo, cómo y para qué, así como la información que se le suministró en el momento de obtenerlo. Esa obligación subsiste en tanto que se siga realizando el tratamiento de los datos personales bajo las condiciones iniciales en que los datos fueron recabados y debe ser verificable en caso de auditoría o inspección.

2. Si el consentimiento del interesado se da en el contexto de una declaración escrita que también se refiera a otros asuntos, la solicitud de consentimiento se presentará de tal forma que se distinga claramente de los demás asuntos, de forma inteligible y de fácil acceso y utilizando un lenguaje claro y sencillo. No será vinculante ninguna parte de la declaración que constituya infracción del presente Reglamento.”.

El sujeto de datos debe conocer una información mínima, previa a la prestación del consentimiento, que resulta crucial para que pueda tomar una decisión válida y claramente informada.

Además, en el presente caso, debe tenerse en cuenta lo preceptuado en el LOPDGDD relativo al “Consentimiento de los menores de edad”,

“1. El tratamiento de los datos personales de un menor de edad únicamente podrá fundarse en su consentimiento cuando sea mayor de catorce años.

Se exceptúan los supuestos en que la ley exija la asistencia de los titulares de la patria potestad o tutela para la celebración del acto o negocio jurídico en cuyo contexto se recaba el consentimiento para el tratamiento.

2. El tratamiento de los datos de los menores de catorce años, fundado en el consentimiento, solo será lícito si consta el del titular de la patria potestad o tutela, con el alcance que determinen los titulares de la patria potestad o tutela.”

Continúa diciendo el COLEGIO que:

2. Por otro lado, consideramos esencial mencionar las medidas de seguridad e instrucciones trasladadas en la gestión de este sistema y que han sido implementadas, en cumplimiento de lo establecido por los artículos 24 y 32 del citado Reglamento Europeo de Protección de Datos:

MEDIDAS DE SEGURIDAD:

El Centro escolar deberá tener la debida diligencia para que el encargado del tratamiento y, en su caso, los subencargados garanticen el cumplimiento de las medidas de seguridad exigibles.

En la Guía para Clientes que contraten servicios de Cloud Computing publicada por la Agencia para asegurarse del cumplimiento de las medidas de seguridad por parte del encargado, se exponen diversos ejemplos:

- *que la plataforma educativa disponga de una certificación*

de seguridad adecuada,

- que se acuerde que un tercero independiente audite las medidas de seguridad identificándolo e indicando los estándares que aplicará,
- que el Centro solicite información sobre cómo se auditarán las medidas de seguridad,
- que el Centro sea informado sobre las incidencias de seguridad que afecten a los datos personales, así como de las medidas adoptadas para resolverlas.

Deben establecerse procedimientos de colaboración entre el responsable y los encargados y subencargados de tratamiento para la implantación y mantenimiento de las medidas de seguridad, ya que la responsabilidad puede ser, en muchos casos, compartida, por lo que deben delimitarse contractualmente las responsabilidades de cada uno de ellos.

El Centro educativo debe adoptar las medidas necesarias para que todos los usuarios del sistema sean conocedores de las políticas del Centro en materia de seguridad.

El Reglamento de Protección de Datos de Carácter Personal obliga a la elaboración de un Documento de Seguridad que recoja las medidas técnicas y organizativas de obligado cumplimiento para todo el personal que accede a los datos personales.

En el caso de que las medidas de seguridad tengan que ser de nivel medio o alto el Centro escolar deberá disponer de un Responsable de Seguridad que se identificará en el Documento de Seguridad. En los contratos suscritos se debe especificar la periodicidad de las copias de seguridad, el responsable de su realización y de la restauración de las bases de datos para que el Centro educativo tenga conocimiento del efectivo cumplimiento de la normativa de protección de datos. Cuando sean exigibles medidas de seguridad de nivel alto, la plataforma educativa deberá garantizar que la copia de seguridad se encuentre en un lugar diferente a la ubicación de las bases de datos originales.

El Centro educativo debe asegurar la debida adecuación de los permisos de acceso a datos personales según el perfil de cada usuario. Para ello, la plataforma educativa deberá colaborar para facilitar la adecuada asignación de perfiles. El responsable del tratamiento tiene que garantizar la confidencialidad e integridad de las contraseñas tanto en la asignación, como en su distribución y almacenamiento. El almacenamiento de las contraseñas debe realizarse cifrado o utilizar un procedimiento que permita que las contraseñas se almacenen de forma ininteligible. Cuando las contraseñas se distribuyan por correo electrónico debe de establecerse un mecanismo de control que garantice que el receptor del correo sea el titular y exija el cambio de contraseña en el primer acceso. Deberán implementarse mecanismos que obliguen al cambio de contraseña con cierta periodicidad, que en ningún caso será superior a un año.

En entornos de tratamiento con niveles de seguridad medio y alto es obligatorio establecer un sistema que limite el intento de accesos no autorizados. Se considera una buena práctica que el Centro escolar conciencie a sus usuarios sobre los peligros de la utilización de contraseñas que no sean lo suficientemente robustas.

Otros aspectos de las Medidas de Seguridad considerados por el Colegio:

El responsable de la plataforma educativa, que actúa como encargado del tratamiento de los datos de los Centros, tiene que establecer mecanismos que aseguren que únicamente el responsable del fichero acceda a su información, garantizando la independencia de los datos.

Las plataformas educativas con medidas de seguridad de nivel alto deberán establecer para la transmisión de los datos un canal seguro mediante el cifrado, o bien utilizar un procedimiento que garantice que la información no sea inteligible.

Cuando se tengan que aplicar las medidas de seguridad de nivel alto es obligatorio que se registren los accesos realizados a los datos, incluidos los accesos denegados, guardando la identificación del usuario, el registro accedido, la fecha y la hora y almacenándose al menos durante dos años. Se deberá revisar esta información como mínimo una vez al mes por el Responsable de Seguridad.

La utilización de sistemas de acceso masivo a los datos, tales como web services, deben realizarse bajo la misma política de seguridad que el resto de los procedimientos incluidos en la plataforma. En las apps para móviles sería conveniente que se solicitará la identificación y autenticación del usuario en cada uno de los accesos a la aplicación, no quedándose almacenada en el dispositivo la identificación suministrada en el primer acceso. Como medida de seguridad adicional, sería una buena práctica que los accesos desde apps se asociasen a los dispositivos, de tal manera que si un usuario se identifica en la plataforma a través de otro dispositivo distinto al habitual se le solicite una autenticación adicional.

En contestación a lo alegado, esta Agencia ya puso de manifiesto que celebra la implementación de las medidas de seguridad adoptadas dados los riesgos estimados.

Si bien, el hecho de que la contraseña del correo electrónico creado por el COLEGIO para todos los niños y niñas del centro fueran las iniciales de la menor más la fecha de nacimiento de la madre, sin forzar el cambio de la misma, evidencia la debilidad y la falta de dichas medidas de seguridad razonables y, en consecuencia, un incumplimiento de las obligaciones del responsable del tratamiento en materia de protección de datos.

La entidad alega que:

3. En relación a la información otorgada en cumplimiento del deber de información, consagrado en el artículo 13 del Reglamento Europeo de Protección de Datos, debemos señalar las siguientes cuestiones:

En primer lugar, reseñar que, la entidad ha adaptado sus sistemas de tratamiento de la información de datos de carácter personal a lo dispuesto en el Reglamento General de Protección de Datos (UE) 2016/679 y a la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y Garantía de los Derechos Digitales.

De igual modo, desde el Colegio, no se permite la recogida de datos, así como el tratamiento, de aquellos datos que no resulten estrictamente

necesarios para la finalidad perseguida en cada caso. Es decir, deben responder a una finalidad legítima, no pudiéndose recabar de manera fraudulenta y cumpliendo con el deber de información respecto a los titulares. Además, los datos serán adecuados, pertinentes y limitados a lo necesario en relación con los fines para los que son tratados. Serán exactos y tendrán que estar actualizados. Se deberán suprimir o actualizar los datos que no son correctos.

En los diferentes documentos facilitados a los tutores o menores del centro, se facilita la información sobre el tratamiento de datos. En prueba de lo anterior, aportamos la matrícula firmada por parte del tutor de la menor (ANEXOIII).

Asimismo, los procedimientos de gestión de ejercicio de derechos en este ámbito, resultan acordes a lo establecido por la normativa actual. En prueba de lo anterior, aportamos los procedimientos implementados por parte del centro y trasladados a través de los diferentes canales del centro. (ANEXO IV).

En relación al cumplimiento de estos procedimientos y la efectividad de los mismos, en el supuesto concreto del tutor, se otorgó la información y respuesta, tal como establece el legislador. En prueba de lo anterior, aportamos requerimiento recibido y respuesta otorgada (ANEXO V).

Asimismo, se ha expuesto por parte de la autoridad de control la falta de información sobre el contacto relativo a la figura del Delegado de Protección de Datos. En este sentido, debemos mostrar nuestro desacuerdo, dado que esta figura se encuentra identificada en nuestros diferentes procedimientos, formularios de recogida de datos, clausulados y en la política de privacidad de nuestra página web.

En contestación a lo alegado, este organismo ya hizo constar que la adaptación de los sistemas de tratamiento de la información de datos de carácter personal a lo dispuesto en el Reglamento General de Protección de Datos (UE) 2016/679 y a la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y Garantía de los Derechos Digitales es una obligación legal.

Si bien y ante lo expuesto, conviene dejar constancia de lo preceptuado en el artículo 13 "Información que deberá facilitarse cuando los datos personales se obtengan del interesado" que establece:

- 1. Cuando se obtengan de un interesado datos personales relativos a él, el responsable del tratamiento, en el momento en que estos se obtengan, le facilitará toda la información indicada a continuación:*
 - a) la identidad y los datos de contacto del responsable y, en su caso, de su representante;*
 - b) los datos de contacto del delegado de protección de datos, en su caso;*
 - c) los fines del tratamiento a que se destinan los datos personales y la base jurídica del tratamiento;*

d) cuando el tratamiento se base en el artículo 6, apartado 1, letra f), los intereses legítimos del responsable o de un tercero;

e) los destinatarios o las categorías de destinatarios de los datos personales, en su caso; f) en su caso, la intención del responsable de transferir datos personales a un tercer país u organización internacional y la existencia o ausencia de una decisión de adecuación de la Comisión, o, en el caso de las transferencias indicadas en los artículos 46 o 47 o el artículo 49, apartado 1, párrafo segundo, referencia a las garantías adecuadas o apropiadas y a los medios para obtener una copia de estas o al lugar en que se hayan puesto a disposición.

Se hace necesario reseñar e insistir por este Organismo que, a fecha del acuerdo de inicio y de la propuesta de resolución de este procedimiento sancionador, siguen sin constar en la política de privacidad del COLEGIO <https://cve.edu.es/politica-de-privacidad> los datos de contacto del delegado de protección de datos, persistiendo en la comisión de la infracción y en el incumplimiento del artículo 13 del RGPD, a pesar de las medidas adoptadas, según consta en diligencia de fecha 1 de julio de 2024.

4. Por parte del centro, consideramos esencial trasladar otras medidas adoptadas, con motivo del incidente surgido en su momento, siendo estas:

En relación al informe relativo a las medidas adoptadas para evitar que se produzcan incidencias similares, fechas de implantación y controles efectuados, se encuentra integrado por las siguientes medidas:

Desde la dirección, somos conscientes de que, en los procesos de gestión de datos, en los que se encuentra involucrado el personal del Colegio, resulta fundamental la formación y concienciación de los mismos, para un adecuado trámite de peticiones, consultas o incidentes que puedan surgir.

Asimismo, en cumplimiento del principio de transparencia, el Colegio, revisa periódicamente cualquier tipo de clausulado, formulario o comunicación efectuada, tal como establece el art. 13 y 14 del Reglamento Europeo de Protección de Datos.

En base a lo anterior, el Responsable del tratamiento, ha definido las siguientes verificaciones, como parte integrante de los diferentes procesos existentes:

- Revisión del clausulado en cumplimiento del deber de información, así como, el consentimiento del titular de los mismos o representante, para cada una de las finalidades del tratamiento de datos.*
- Además, desde el centro, plenamente conscientes de que, la gestión de estos procesos depende del conocimiento por parte del usuario encargado en el Colegio, se procedió el durante el ejercicio de 2022, a la elaboración de un programa formativo, para lograr alcanzar esta cultura de protección de datos.*

En este sentido, en esta primera organización, la formación se destinó a los trabajadores/as encargados de la gestión de comunicaciones, bajo el objetivo de formación y concienciación de la totalidad, siendo el contenido del programa formativo:

UNIDAD 1. EL REGLAMENTO EUROPEO DE PROTECCIÓN DE DATOS (UE) 2016/679

UNIDAD 2. FUNDAMENTOS PARA EL TRATAMIENTO DE DATOS

UNIDAD 3. RESPONSABLE Y ENCARGADO DE TRATAMIENTO

UNIDAD 4. DERECHOS DE LOS INTERESADOS

UNIDAD 5. MEDIDAS DE RESPONSABILIDAD ACTIVA I

UNIDAD 6. MEDIDAS DE RESPONSABILIDAD ACTIVA II

Tal y como anticipamos con anterioridad, los procesos de gestión en materia de protección de datos, se encuentran en constante revisión y valoración, debido a que, desde la entidad, somos conscientes de la exposición constante y necesidad de cumplimiento de las garantías que establece la normativa vigente.

Asimismo, cabe destacar que, el Colegio, como Responsable del tratamiento, ha adoptado diferentes medidas con el fin de implantar una cultura y concienciación en materia de protección de datos.

En primer lugar, resaltar que el Colegio, se encuentra adaptado a la normativa vigente en materia de protección de datos (Reglamento (UE) 2016/679 del Parlamento Europeo y del Consejo, de 27 de abril, relativo a la protección de las personas físicas y la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos de Carácter Personal y Garantía de los Derechos Digitales), cumplimiento de las obligaciones formales que se establecen a tal efecto por el legislador, siendo estas las siguientes:

- *Registro de Actividades del tratamiento (contenido mínimo del art. 30 del RGPD).*
- *Regulación de las relaciones con terceros, mediante la firma de los contratos de confidencialidad y acceso a datos por cuenta de terceros (art. 28 del RGPD y art. 33 Ley Orgánica 3/2018, de 5 de diciembre, de protección de datos de carácter personal y garantía de los digitales).*
- *Documentos de confidencialidad y deber de secreto de los diferentes usuarios.*
- *Verificación de las medidas de seguridad implantadas, conforme a lo establecido en el art. 24 y 32 del RGPD.*

Como parte integrante de las medidas técnico-organizativas para garantizar la seguridad de la información (confidencialidad, integridad y disponibilidad de los datos y del sistema en general), se han elaborado los clausulados y documentos necesarios para que los trabajadores y personal dependiente del RT los suscribiese y, a su vez, sean formados acerca de sus obligaciones en materia de Protección de Datos, de las consecuencias en caso de incumplimiento de sus obligaciones, de su deber de secreto y confidencialidad con respecto a los

datos e informaciones que conozcan por su relación laboral o mercantil con el RT, etc.; con respecto a este colectivo, en su calidad de titulares de los datos, se elaboraron las cláusulas necesarias para obtener su consentimiento informado para los distintos tratamientos que el RT realiza con sus datos. Por último, entre estas cláusulas se incluyeron aquellas que deberán formar a los trabajadores con respecto a la normativa interna del RT en las llamadas Políticas TIC, que incluyen las normas de uso de los equipos, internet, correos corporativos o privados en los equipos o recursos el RT, accesos y operaciones autorizados, etc.

- *Clausulas informativas elaboradas para los distintos documentos que son usados para la actividad habitual de la entidad.*
- *Procedimiento implantado ante ejercicio de derechos por parte de titulares.*
- *Procedimiento ante brechas o incidentes de seguridad.*
- *De igual modo, en su día, se procedió a la designación de la figura del Delegado de Protección de datos, así como, a su comunicación ante esta autoridad de control, en el plazo legal establecido a tal efecto.*

En cuanto a la Política general de Seguridad, aprobada por el Colegio y que resulta la base establecida como proceso de adaptación normativa en la entidad Responsable del tratamiento:

1.- Derechos de las personas en relación con los datos de carácter personal.

Los titulares de los datos pueden ejercer sus Derechos de acceso, oposición, rectificación, cancelación o supresión (derecho al olvido), revocación del consentimiento, limitación del tratamiento y portabilidad de los datos con arreglo la Legislación vigente, mediante carta dirigida a nuestra dirección, o contactando con nuestro DPO: dpo@grupodata.es, o cualquier otro medio, debiendo acreditar su identidad. De igual modo, tiene derecho a presentar reclamación ante la Agencia Española de Protección de Datos. Entiendo que esta información, la del derecho a reclamar ante la AEPD, no es preceptiva su información, en este caso, pues el documento se refiere a la política de la empresa; declara aquello que incumbe, exclusivamente, a la empresa.

2.- Recogida de datos e información. La recogida de datos de carácter personal se realizará única y exclusivamente para los fines previstos en las actividades directamente relacionadas con el objeto social y fines de la entidad y utilizando métodos que hayan sido aprobados por el Responsable del tratamiento.

3.- Tratamiento y consentimiento.

Se informará a las personas de las que se requieran datos de carácter personal de los derechos que les asisten y se obtendrá su consentimiento por los métodos establecidos y en los términos que requiere la legislación aplicable.

4.- Transmisiones, Confidencialidad y Deber de Secreto.

Todas las comunicaciones referidas a datos de carácter personal entre el Colegio y los interesados, y cualquier otra entidad o persona que intervenga en el tratamiento, serán consideradas confidenciales.

Todos los intervinientes en el tratamiento dejarán evidencia de su compromiso de confidencialidad.

5.- Cesión de información personal a terceros.

El Colegio, no vende, cede, arrienda ni transmite, de modo alguno, información o datos de carácter personal de sus Clientes/Usuarios a terceros, salvo las cesiones amparadas por Ley y a los Encargados del Tratamiento autorizados.

Los cambios que afecten al tratamiento de datos personales se comunicarán también a los interesados por los medios más adecuados en cada caso.

6.- Responsabilidad, cooperación y participación.

El Colegio, como Responsable del Tratamiento, solicita el compromiso y la participación activa de todo el personal para la correcta aplicación, actualización y perfeccionamiento de esta Política de Protección de Datos.

En contestación a lo alegado, esta Agencia ya señaló que, la adopción de todas estas medidas como consecuencia del incidente surgido en su momento denota una ausencia de medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo del tratamiento.

El artículo 32 del RGPD no establece un listado de las medidas de seguridad que sean de aplicación de acuerdo con los datos que son objeto de tratamiento, sino que establece que el responsable y el encargado del tratamiento aplicarán medidas técnicas y organizativas que sean adecuadas al riesgo que conlleve el tratamiento, teniendo en cuenta el estado de la técnica, los costes de aplicación, la naturaleza, alcance, contexto y finalidades del tratamiento, los riesgos de probabilidad y gravedad para los derechos y libertades de las personas interesadas.

Asimismo, las medidas de seguridad deben resultar adecuadas y proporcionadas al riesgo detectado, señalando que la determinación de las medidas técnicas y organizativas deberá realizarse teniendo en cuenta, entre otros: la seudonimización y el cifrado, la capacidad para garantizar la confidencialidad, integridad, disponibilidad y resiliencia, la capacidad para restaurar la disponibilidad y acceso a datos tras un incidente, proceso de verificación (que no auditoría), evaluación y valoración de la eficacia de las medidas.

Es evidente que, las medidas de seguridad implantadas eran insuficientes.

Independientemente de las medidas adoptadas para evitar que se produjesen incidencias similares, así como de las demás medidas adoptadas, lo determinante es que no había medidas suficientes o no se habían implantado correctamente en el momento que se produjo el incidente.

Si bien, esta Agencia pone en valor el esfuerzo hecho por el COLEGIO para cumplir su obligación, como responsable del tratamiento de datos, de aplicar las medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo en el tratamiento de datos personales.

Evidentemente, la formación y concienciación en materia de protección de datos del personal que presta sus servicios en el COLEGIO entra dentro de la obligación del responsable del tratamiento de aplicar las medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo.

Pues dichas medidas organizativas de factor humano son imprescindibles e importantísimas para evitar, prevenir, reaccionar y minorar los efectos ante incidentes como el ocurrido.

Por último y en referencia a lo expuesto, es necesario hacer constar la sentencia de la AN de 9 de febrero de 2023 (rec. 770/2022) que dice:

“(…) Las medidas de seguridad implementadas con posterioridad, no afectan a la comisión de la infracción y contrariamente a lo pretendido por la actora no pueden amparar la aplicación de una eximente, sin perjuicio de que hayan sido tomada en consideración como atenuante del artículo 83.2.c) del RGPD a la hora de fijar la sanción”.

En consecuencia y tratándose de una reiteración de las manifestaciones ya expuestas, SE DESESTIMAN nuevamente las alegaciones.

IV

Obligación incumplida. Licitud del tratamiento

El artículo 6 del RGPD, establece, sobre la licitud del tratamiento de datos personales obtenidos de los usuarios que, el tratamiento de éstos solo será lícito si se cumple al menos una de las condiciones indicadas en su apartado primero, entre las que se encuentra, en su apartado a): *“que el interesado haya dado su consentimiento para el tratamiento de sus datos personales para uno o varios fines específicos (...)”.*

En cuanto al tratamiento de datos basado en el consentimiento del interesado, el artículo 7 del RGPD indica que, el responsable del tratamiento deberá ser capaz de demostrar que el interesado consintió el tratamiento de sus datos personales. Si el consentimiento se otorgara en el contexto de una declaración escrita que refiera también a otros temas, se obliga a que la solicitud de consentimiento se distinga claramente de los demás asuntos y se presente de forma inteligible, de fácil acceso y utilizando un lenguaje claro y sencillo. Se exige, además, que se le proporcione información adicional al interesado, entre otros, cuáles serán las categorías de datos a

tratar, las finalidades para las que se solicita el consentimiento y el derecho a retirar el consentimiento en cualquier momento.

En cuanto al modo de obtener el consentimiento del interesado para el tratamiento en cuestión, el considerando 32 del RGPD dispone que éste, *“debe darse mediante un acto afirmativo claro que refleje una manifestación de voluntad libre, específica, informada e inequívoca del interesado de aceptar el tratamiento de datos de carácter personal que le conciernen”* y que *“el silencio, las casillas ya marcadas o la inacción no deben constituir consentimiento”*. Asimismo, se exige que el consentimiento se otorgue *“para todas las actividades de tratamiento realizadas con el mismo o los mismos fines. Cuando el tratamiento tenga varios fines, debe darse el consentimiento para todos ellos”*. Por último, establece que, *“si el consentimiento del interesado se ha de dar a raíz de una solicitud por medios electrónicos, la solicitud ha de ser clara, concisa y no perturbar innecesariamente el uso del servicio para el que se presta”*.

Por su parte el artículo 7 LOPDGDD dedicado al “Consentimiento de los menores de edad”, establece que,

1. El tratamiento de los datos personales de un menor de edad únicamente podrá fundarse en su consentimiento cuando sea mayor de catorce años. Se exceptúan los supuestos en que la ley exija la asistencia de los titulares de la patria potestad o tutela para la celebración del acto o negocio jurídico en cuyo contexto se recaba el consentimiento para el tratamiento.

2. El tratamiento de los datos de los menores de catorce años, fundado en el consentimiento, solo será lícito si consta el del titular de la patria potestad o tutela, con el alcance que determinen los titulares de la patria potestad o tutela.

En el presente caso, la parte reclamante manifiesta que el COLEGIO creó a su hija menor de 14 años un correo electrónico *****EMAIL.1**, sin haber recabado el consentimiento de los tutores para la creación de dicho correo electrónico.

Puesto que la hija de la parte reclamante es menor de 14 años, en relación a la creación de dicho correo electrónico, debería constar el consentimiento o autorización de los titulares de la patria potestad o tutela de la menor para la creación del correo electrónico *****EMAIL.1**, debiendo ser el responsable del tratamiento capaz de demostrar que los titulares de la patria potestad o tutela de la menor consintieron el tratamiento de los datos personales de la menor, conforme a lo establecido en el artículo 7 del RGPD, circunstancia esta que no consta en el expediente.

En consecuencia, se consideran que los hechos acaecidos son constitutivos de una infracción, imputable al COLEGIO, por vulneración del artículo 6.1 del RGPD.

V

Tipificación y calificación de la infracción del artículo 6.1 del RGPD.

La citada infracción del artículo 7.2 del RGPD supone la comisión de las infracciones tipificadas en el artículo 83.5 del RGPD que bajo la rúbrica *“Condiciones generales para la imposición de multas administrativas”* dispone:

“Las infracciones de las disposiciones siguientes se sancionarán, de acuerdo con el apartado 2, con multas administrativas de 20 000 000 EUR como máximo o, tratándose de una empresa, de una cuantía equivalente al 4 % como máximo del volumen de negocio total anual global del ejercicio financiero anterior, optándose por la de mayor cuantía:

a) los principios básicos para el tratamiento, incluidas las condiciones para el consentimiento a tenor de los artículos 5, 6, 7 y 9; (...)”

A este respecto, la LOPDGDD, en su artículo 71 “Infracciones” establece que “Constituyen infracciones los actos y conductas a las que se refieren los apartados 4, 5 y 6 del artículo 83 del Reglamento (UE) 2016/679, así como las que resulten contrarias a la presente ley orgánica”.

A efectos del plazo de prescripción, el artículo 72 “Infracciones consideradas muy graves” de la LOPDGDD indica:

“1. En función de lo que establece el artículo 83.5 del Reglamento (UE) 2016/679 se consideran muy graves y prescribirán a los tres años las infracciones que supongan una vulneración sustancial de los artículos mencionados en aquel y, en particular, las siguientes:

b) El tratamiento de datos personales sin que concurra alguna de las condiciones de licitud del tratamiento establecidas en el artículo 6 del Reglamento (UE) 2016/679. (...)”

VI

Sanción por la infracción del artículo 6.1 del RGPD

A efectos de decidir sobre la imposición de una multa administrativa y su cuantía, procede graduar la sanción a imponer de acuerdo con los siguientes criterios que establece el artículo 83.2 del RGPD:

Como circunstancia a tener en cuenta en la fijación de la sanción:

- *b) la intencionalidad o negligencia en la infracción;*

En este mismo sentido, el Tribunal Supremo viene entendiendo que existe imprudencia siempre que se desatiende un deber legal de cuidado, es decir, cuando el infractor no se comporta con la diligencia exigible. Y en la valoración del grado de diligencia ha de ponderarse especialmente la profesionalidad o no del sujeto, y no cabe duda de que, en el caso ahora examinado, cuando la actividad de la recurrente es de constante y abundante manejo de datos de carácter personal ha de insistirse en el rigor y el exquisito cuidado por ajustarse a las prevenciones legales al respecto. [Sentencia de la Audiencia Nacional de 17/10/2007 (rec. 63/2006)].

Asimismo, se considera que procede graduar la sanción a imponer de acuerdo con los siguientes criterios que establece el apartado 2 del artículo 76 “Sanciones y medidas correctivas” de la LOPDGDD:

Como circunstancia a tener en cuenta en la fijación de la sanción:

- *b) La vinculación de la actividad del infractor con la realización de tratamientos de datos personales.*

El COLEGIO, en ejercicio de su actividad educativa y en el concreto tratamiento de datos personales objeto del presente procedimiento sancionador, trata de manera habitual datos personales tanto de los docentes como de los alumnos del centro. A este respecto, ha de destacarse que la dirección de correo electrónico tiene como base la inicial y el primer apellido de la hija de la reclamante y que la contraseña establecida era la fecha de nacimiento de la madre. Todos ellos, por lo tanto, datos personales objeto de tratamiento por la reclamada.

- *f) La afectación a los derechos de los menores.*

La creación de un correo electrónico, así como la utilización de las distintas aplicaciones educativas, sin haber recabado el consentimiento de sus padres o tutores, afecta a una alumna del COLEGIO menor de edad.

El balance de las circunstancias contempladas en el artículo 83.2 del RGPD y el artículo 76.2 de la LOPDGDD, con respecto a la infracción cometida al vulnerar lo establecido en el artículo 6.1 del RGPD, permite fijar una sanción de 4.500€ (CUATRO MIL QUINIENTOS EUROS).

VII

Artículo 13 RGPD

El artículo 13 “*Información que deberá facilitarse cuando los datos personales se obtengan del interesado*” establece que:

1. Cuando se obtengan de un interesado datos personales relativos a él, el responsable del tratamiento, en el momento en que estos se obtengan, le facilitará toda la información indicada a continuación:

- a) la identidad y los datos de contacto del responsable y, en su caso, de su representante;*
- b) los datos de contacto del delegado de protección de datos, en su caso;*
- c) los fines del tratamiento a que se destinan los datos personales y la base jurídica del tratamiento;*
- d) cuando el tratamiento se base en el artículo 6, apartado 1, letra f), los intereses legítimos del responsable o de un tercero;*
- e) los destinatarios o las categorías de destinatarios de los datos personales, en su caso;*
- f) en su caso, la intención del responsable de transferir datos personales a un tercer país u organización internacional y la existencia o ausencia de una decisión de adecuación de la Comisión, o, en el caso de las transferencias*

indicadas en los artículos 46 o 47 o el artículo 49, apartado 1, párrafo segundo, referencia a las garantías adecuadas o apropiadas y a los medios para obtener una copia de estas o al lugar en que se hayan puesto a disposición.

Una política de privacidad (privacy policy) es una presentación por escrito de todas las medidas que aplica una empresa u organización para garantizar la seguridad y el uso lícito de los datos personales de los usuarios o clientes que recoge y trata en el contexto de cualquier relación, ya sea comercial o prestacional.

El contenido de la política de privacidad debe ajustarse a la información que debe facilitarse cuando los datos se obtengan del interesado.

En el presente caso, en la política de privacidad del COLEGIO <https://cve.edu.es/politica-de-privacidad> no constaban los datos de contacto del delegado de protección de datos, tal y como ya se puso de manifiesto en el acuerdo de inicio de este procedimiento. Esta Agencia ha constatado que siguen sin constar a fecha de la presente resolución.

En consecuencia, los hechos conocidos son constitutivos de una infracción, imputable al COLEGIO, por vulneración del artículo 13 del RGPD.

VIII

Tipificación y calificación de la infracción del artículo 13 del RGPD.

La citada infracción del artículo 13 del RGPD supone la comisión de las infracciones tipificadas en el artículo 83.5 del RGPD que bajo la rúbrica “*Condiciones generales para la imposición de multas administrativas*” dispone:

“Las infracciones de las disposiciones siguientes se sancionarán, de acuerdo con el apartado 2, con multas administrativas de 20 000 000 EUR como máximo o, tratándose de una empresa, de una cuantía equivalente al 4 % como máximo del volumen de negocio total anual global del ejercicio financiero anterior, optándose por la de mayor cuantía:

b) los derechos de los interesados a tenor de los artículos 12 a 22;(…)”

A este respecto, la LOPDGDD, en su artículo 71 “*Infracciones*” establece que “*Constituyen infracciones los actos y conductas a las que se refieren los apartados 4, 5 y 6 del artículo 83 del Reglamento (UE) 2016/679, así como las que resulten contrarias a la presente ley orgánica*”.

A efectos del plazo de prescripción, el artículo 74 “*Infracciones consideradas leves*” de la LOPDGDD indica:

“1. Se consideran leves y prescribirán al año las restantes infracciones de carácter meramente formal de los artículos mencionados en los apartados 4 y 5 del artículo 83 del Reglamento (UE) 2016/679 y, en particular, las siguientes:

(…)

a) El incumplimiento del principio de transparencia de la información o el derecho de información del afectado por no facilitar toda la información exigida por los artículos 13 y 14 del Reglamento (UE) 2016/679. (...)”.

IX

Sanción por la infracción del artículo 13 del RGPD

A efectos de decidir sobre la imposición de una multa administrativa y su cuantía, procede graduar la sanción a imponer de acuerdo con los siguientes criterios que establece el artículo 83.2 del RGPD:

Como circunstancia a tener en cuenta en la fijación de la sanción:

- *b) la intencionalidad o negligencia en la infracción;*

En este mismo sentido, el Tribunal Supremo viene entendiendo que existe imprudencia siempre que se desatiende un deber legal de cuidado, es decir, cuando el infractor no se comporta con la diligencia exigible. Y en la valoración del grado de diligencia ha de ponderarse especialmente la profesionalidad o no del sujeto, y no cabe duda de que, en el caso ahora examinado, cuando la actividad de la recurrente es de constante y abundante manejo de datos de carácter personal ha de insistirse en el rigor y el exquisito cuidado por ajustarse a las prevenciones legales al respecto. [Sentencia de la Audiencia Nacional de 17/10/2007 (rec. 63/2006)].

Asimismo, se considera que procede graduar la sanción a imponer de acuerdo con los siguientes criterios que establece el apartado 2 del artículo 76 “Sanciones y medidas correctivas” de la LOPDGDD:

Como circunstancia a tener en cuenta en la fijación de la sanción:

- *b) La vinculación de la actividad del infractor con la realización de tratamientos de datos personales.*

El COLEGIO, en ejercicio de su actividad educativa, trata de manera habitual datos personales tanto de los docentes como de los alumnos del centro. Este hecho hace especialmente relevante que exista información adecuada y transparente que permita un adecuado ejercicio de los derechos que ostentan los titulares de los datos objeto de tratamiento y, en concreto, de su delegado de protección de datos

El balance de las circunstancias contempladas en el artículo 83.2 del RGPD y el artículo 76.2 de la LOPDGDD, con respecto a la infracción cometida al vulnerar lo establecido en el artículo 13 del RGPD, permite fijar una sanción de 1.000€ (MIL EUROS).

X

Artículo 32 del RGPD

El Artículo 32 “Seguridad del tratamiento” del RGPD establece:

“1. Teniendo en cuenta el estado de la técnica, los costes de aplicación, y la naturaleza, el alcance, el contexto y los fines del tratamiento, así como riesgos de probabilidad y gravedad variables para los derechos y libertades de las personas físicas, el responsable y el encargado del tratamiento aplicarán medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo, que en su caso incluya, entre otros:

- a) la seudonimización y el cifrado de datos personales;*
- b) la capacidad de garantizar la confidencialidad, integridad, disponibilidad y resiliencia permanentes de los sistemas y servicios de tratamiento;*
- c) la capacidad de restaurar la disponibilidad y el acceso a los datos personales de forma rápida en caso de incidente físico o técnico;*
- d) un proceso de verificación, evaluación y valoración regulares de la eficacia de las medidas técnicas y organizativas para garantizar la seguridad del tratamiento.*

2. Al evaluar la adecuación del nivel de seguridad se tendrán particularmente en cuenta los riesgos que presente el tratamiento de datos, en particular como consecuencia de la destrucción, pérdida o alteración accidental o ilícita de datos personales transmitidos, conservados o tratados de otra forma, o la comunicación o acceso no autorizados a dichos datos.

3. La adhesión a un código de conducta aprobado a tenor del artículo 40 o a un mecanismo de certificación aprobado a tenor del artículo 42 podrá servir de elemento para demostrar el cumplimiento de los requisitos establecidos en el apartado 1 del presente artículo.

4. El responsable y el encargado del tratamiento tomarán medidas para garantizar que cualquier persona que actúe bajo la autoridad del responsable o del encargado y tenga acceso a datos personales solo pueda tratar dichos datos siguiendo instrucciones del responsable, salvo que esté obligada a ello en virtud del Derecho de la Unión o de los Estados miembros”.

Así, dicho precepto obliga a la adopción de medidas de seguridad, que pueden ser de índole técnica u organizativa, y que deberán ser adecuadas al riesgo del tratamiento de datos personales realizados. A *sensu contrario* dicho precepto se vería vulnerado si no se adoptasen dichas medidas que, adecuadas al riesgo y con carácter general, garantizaran la seguridad del tratamiento.

La obligación de adoptar todas las medidas técnicas y organizativas impuesta por el artículo 32 del RGPD al responsable del tratamiento es una manifestación de los dos pilares esenciales del RGPD: la responsabilidad proactiva consagrada en el artículo 5.2 y desarrollada en el artículo 24.1 del RGPD y el enfoque de riesgos. Así, el artículo 32, si bien establece un conjunto de medidas que podrían considerarse mínimas a adoptar por el responsable, en ningún caso puede entenderse como un *numerus clausus* puesto que estas deben atender a la naturaleza, el alcance, el contexto y los fines del tratamiento, así como riesgos de probabilidad y gravedad que afecten a los datos personales.

Como se puede observar, se ha evolucionado de un sistema reactivo a uno proactivo, basado en la prevención y no en la respuesta a una incidencia concreta que mereciera

ser corregida, y que debe operar durante todo el ciclo de vida de los datos personales. A este respecto se pronuncia el Considerando 74 del RGPD cuando señala (el subrayado es de la AEPD):

“74 Debe quedar establecida la responsabilidad del responsable del tratamiento por cualquier tratamiento de datos personales realizado por él mismo o por su cuenta. En particular, el responsable debe estar obligado a aplicar medidas oportunas y eficaces y ha de poder demostrar la conformidad de las actividades de tratamiento con el presente Reglamento, incluida la eficacia de las medidas. Dichas medidas deben tener en cuenta la naturaleza, el ámbito, el contexto y los fines del tratamiento, así como el riesgo para los derechos y libertades de las personas físicas”.

Por su parte, la STS de 15 de febrero 2022 (Rec. 7359/2020) indica que “No basta con diseñar los medios técnicos y organizativos necesarios también es necesaria su correcta implantación y su utilización de forma apropiada, de modo que también responderá por la falta de la diligencia en su utilización, entendida como una diligencia razonable atendiendo a las circunstancias del caso”.

Asimismo, el TJUE en sentencia de 14 de diciembre de 2023, en el asunto C-340/21 se ha pronunciado sobre “si el principio de responsabilidad del responsable del tratamiento, enunciado en el artículo 5, apartado 2, del RGPD y desarrollado en el artículo 24 de este, debe interpretarse en el sentido de que, ... el responsable del tratamiento soporta la carga de la prueba del carácter apropiado de las medidas de seguridad que ha adoptado con arreglo al artículo 32 del mencionado Reglamento”, concluyendo que “Del tenor de los artículos 5, apartado 2, 24, apartado 1, y 32, apartado 1, del RGPD se desprende inequívocamente que la carga de la prueba de que los datos personales se tratan de modo que se garantiza una seguridad adecuada, en el sentido de los artículos 5, apartado 1, letra f), y 32 de dicho Reglamento, incumbe al responsable del tratamiento en cuestión [véanse, por analogía, las sentencias de 4 de mayo de 2023, Bundesrepublik Deutschland (Buzón electrónico judicial), C-60/22, EU: C:2023:373, apartados 52 y 53, y de 4 de julio de 2023, Meta Platforms y otros (Condiciones generales del servicio de una red social), C-252/21, EU:C:2023:537, apartado 95].” (apartado 52)

Dicha STJUE también indica lo siguiente:

“[la adopción de medidas de seguridad en materia de protección de datos de carácter personal] no se cumple con la adopción de cualquier medida, pues deben ser las necesarias para garantizar aquellos objetivos que marca el precepto, y por supuesto, no basta con la aprobación formal de las medidas de seguridad, ya que resulta exigible que aquéllas se instauren y pongan en práctica de manera efectiva. Hemos considerado, en consecuencia, que se impone una obligación de resultado, consistente en que se adopten las medidas necesarias para evitar que los datos se pierdan, extravíen o acaben en manos de terceros. En definitiva, todo responsable de un fichero (o encargada de tratamiento) es, por disposición legal, una deudora de seguridad en materia de datos debiendo asegurarse de que dichas medidas o mecanismos se implementen de manera efectiva en la práctica.”

En definitiva, nos encontramos ante una obligación del responsable del tratamiento consistente en la adopción de medidas de seguridad de índole técnica y organizativa y que corresponde a dicho responsable demostrar su implantación y su adecuación en atención al riesgo derivado del tratamiento.

Teniendo en cuenta lo anterior, en el presente caso, en el momento de producirse los hechos, consta que el COLEGIO, no disponía de las medidas de seguridad razonables en función de los posibles riesgos estimados, sobre todo al tratarse de una vía de comunicación del COLEGIO con sus alumnos y al ser estos menores de edad.

El hecho de que la contraseña del correo electrónico para todos los niños y niñas del colegio fueran las iniciales de la menor más la fecha de nacimiento de la madre, sin forzar el cambio de la misma, evidencia la falta de dichas medidas de seguridad razonables.

En consecuencia, los hechos conocidos son constitutivos de una infracción, imputable al COLEGIO, por vulneración del artículo 32 del RGPD.

XI

Tipificación de la infracción del artículo 32 del RGPD

La citada infracción del artículo 32 del RGPD supone la comisión de las infracciones tipificadas en el artículo 83.4 del RGPD que bajo la rúbrica *“Condiciones generales para la imposición de multas administrativas”* dispone:

“Las infracciones de las disposiciones siguientes se sancionarán, de acuerdo con el apartado 2, con multas administrativas de 10 000 000 EUR como máximo o, tratándose de una empresa, de una cuantía equivalente al 2 % como máximo del volumen de negocio total anual global del ejercicio financiero anterior, optándose por la de mayor cuantía:

a) las obligaciones del responsable y del encargado a tenor de los artículos 8, 11, 25 a 39, 42 y 43; (...)”

A este respecto, la LOPDGDD, en su artículo 71 *“Infracciones”* establece que *“Constituyen infracciones los actos y conductas a las que se refieren los apartados 4, 5 y 6 del artículo 83 del Reglamento (UE) 2016/679, así como las que resulten contrarias a la presente ley orgánica”*.

A efectos del plazo de prescripción, el artículo 73 *“Infracciones consideradas graves”* de la LOPDGDD indica:

“En función de lo que establece el artículo 83.4 del Reglamento (UE) 2016/679 se consideran graves y prescribirán a los dos años las infracciones que supongan una vulneración sustancial de los artículos mencionados en aquel y, en particular, las siguientes:

(...)

f) La falta de adopción de aquellas medidas técnicas y organizativas que resulten apropiadas para garantizar un nivel de seguridad adecuado al

riesgo del tratamiento, en los términos exigidos por el artículo 32.1 del Reglamento (UE) 2016/679.

XII

Sanción por la infracción del artículo 32 del RGPD

A efectos de decidir sobre la imposición de una multa administrativa y su cuantía, se considera que la infracción en cuestión es grave a los efectos del RGPD y que procede graduar la sanción a imponer de acuerdo con los siguientes criterios que establece el artículo 83.2 del RGPD:

Como circunstancia a tener en cuenta en la fijación de la sanción:

- *b) la intencionalidad o negligencia en la infracción;*

En este mismo sentido, el Tribunal Supremo viene entendiendo que existe imprudencia siempre que se desatiende un deber legal de cuidado, es decir, cuando el infractor no se comporta con la diligencia exigible. Y en la valoración del grado de diligencia ha de ponderarse especialmente la profesionalidad o no del sujeto, y no cabe duda de que, en el caso ahora examinado, cuando la actividad de la recurrente es de constante y abundante manejo de datos de carácter personal ha de insistirse en el rigor y el exquisito cuidado por ajustarse a las prevenciones legales al respecto. [Sentencia de la Audiencia Nacional de 17/10/2007 (rec. 63/2006)].

Asimismo, se considera que procede graduar la sanción a imponer de acuerdo con los siguientes criterios que establece el apartado 2 del artículo 76 “Sanciones y medidas correctivas” de la LOPDGDD:

Como circunstancia a tener en cuenta en la fijación de la sanción:

- *b) La vinculación de la actividad del infractor con la realización de tratamientos de datos personales.*

El COLEGIO, en ejercicio de su actividad educativa y en el concreto tratamiento de datos personales objeto del presente procedimiento sancionador, trata de manera habitual datos personales tanto de los docentes como de los alumnos del centro. A este respecto, ha de destacarse que la dirección de correo electrónico tiene como base la inicial y el primer apellido de la hija de la reclamante y que la contraseña establecida era la fecha de nacimiento de la madre. Todos ellos, por lo tanto, datos personales objeto de tratamiento por la reclamada.

- *f) La afectación a los derechos de los menores.*

La creación de un correo electrónico, así como la utilización de las distintas aplicaciones educativas, para lo que no se contaba con las medidas de seguridad necesarias, afecta a una alumna del COLEGIO menor de edad.

El balance de las circunstancias contempladas en el artículo 83.2 del RGPD y el artículo 76.2 de la LOPDGDD, con respecto a la infracción cometida al vulnerar lo

establecido en el artículo 32 del RGPD, permite fijar una sanción de 4.500€ (CUATRO MIL QUINIENTOS EUROS).

Por lo tanto, de acuerdo con la legislación aplicable y valorados los criterios de graduación de las sanciones cuya existencia ha quedado acreditada, la Presidencia de la Agencia Española de Protección de Datos RESUELVE:

PRIMERO: IMPONER a COLEGIO VIRGEN DE EUROPA, S.L., con NIF B28773794, por una infracción del artículo 6.1 del RGPD y de artículo 13 del RGPD tipificadas en el artículo 83.5 del RGPD, y por una infracción del artículo 32 del RGPD tipificada en el artículo 83.4 del RGPD, con las siguientes multas:

- Por la infracción del artículo 6.1 del RGPD, tipificada en el artículo 83.5 de dicha norma, multa administrativa de cuantía 4.500,00 euros.
- Por la infracción del artículo 13 del RGPD, tipificada en el artículo 83.5 de dicha norma, multa administrativa de cuantía 1.000,00 euros.
- Por la infracción del artículo 32 del RGPD, tipificada en el artículo 83.4 de dicha norma, multa administrativa de cuantía 4.500,00 euros.

SEGUNDO: NOTIFICAR la presente resolución a COLEGIO VIRGEN DE EUROPA, S.L.

TERCERO: Esta resolución será ejecutiva una vez finalice el plazo para interponer el recurso potestativo de reposición (un mes a contar desde el día siguiente a la notificación de esta resolución) sin que el interesado haya hecho uso de esta facultad. Se advierte al sancionado que deberá hacer efectiva la sanción impuesta una vez que la presente resolución sea ejecutiva, de conformidad con lo dispuesto en el art. 98.1.b) de la ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas (en adelante LPACAP), en el plazo de pago voluntario establecido en el art. 68 del Reglamento General de Recaudación, aprobado por Real Decreto 939/2005, de 29 de julio, en relación con el art. 62 de la Ley 58/2003, de 17 de diciembre, mediante su ingreso, indicando el NIF del sancionado y el número de procedimiento que figura en el encabezamiento de este documento, en la cuenta restringida nº **IBAN: ES00-0000-0000-0000-0000-0000 (BIC/Código SWIFT: CAIXESBBXXX)**, abierta a nombre de la Agencia Española de Protección de Datos en la entidad bancaria CAIXABANK, S.A.. En caso contrario, se procederá a su recaudación en período ejecutivo.

Recibida la notificación y una vez ejecutiva, si la fecha de ejecutividad se encuentra entre los días 1 y 15 de cada mes, ambos inclusive, el plazo para efectuar el pago voluntario será hasta el día 20 del mes siguiente o inmediato hábil posterior, y si se encuentra entre los días 16 y último de cada mes, ambos inclusive, el plazo del pago será hasta el 5 del segundo mes siguiente o inmediato hábil posterior.

De conformidad con lo establecido en el artículo 50 de la LOPDGDD, la presente Resolución se hará pública una vez haya sido notificada a los interesados.

Contra esta resolución, que pone fin a la vía administrativa conforme al art. 48.6 de la LOPDGDD, y de acuerdo con lo establecido en el artículo 123 de la LPACAP, los interesados podrán interponer, potestativamente, recurso de reposición ante la Presidencia de la Agencia Española de Protección de Datos en el plazo de un mes a contar desde el día siguiente a la notificación de esta resolución o directamente recurso contencioso administrativo ante la Sala de lo Contencioso-administrativo de la Audiencia Nacional, con arreglo a lo dispuesto en el artículo 25 y en el apartado 5 de la disposición adicional cuarta de la Ley 29/1998, de 13 de julio, reguladora de la Jurisdicción Contencioso-administrativa, en el plazo de dos meses a contar desde el día siguiente a la notificación de este acto, según lo previsto en el artículo 46.1 de la referida Ley.

Finalmente, se señala que conforme a lo previsto en el art. 90.3 a) de la LPACAP, se podrá suspender cautelarmente la resolución firme en vía administrativa si el interesado manifiesta su intención de interponer recurso contencioso-administrativo. De ser éste el caso, el interesado deberá comunicar formalmente este hecho mediante escrito dirigido a la Agencia Española de Protección de Datos, presentándolo a través del Registro Electrónico de la Agencia [<https://sedeaepd.gob.es/sede-electronica-web/>], o a través de alguno de los restantes registros previstos en el art. 16.4 de la citada Ley 39/2015, de 1 de octubre. También deberá trasladar a la Agencia la documentación que acredite la interposición efectiva del recurso contencioso-administrativo. Si la Agencia no tuviese conocimiento de la interposición del recurso contencioso-administrativo en el plazo de dos meses desde el día siguiente a la notificación de la presente resolución, daría por finalizada la suspensión cautelar.

938-100325

Lorenzo Cotino Hueso
Presidente de la Agencia Española de Protección de Datos